



Briefing (Gruppe 1): Alpenzuckerl Manufaktur GmbH

1. Unternehmen im Überblick

Die *Alpenzuckerl Manufaktur GmbH* stellt in einem Produktionsstandort in Hallein hochwertige Süßwaren und Schokolade her und vertreibt diese über den Lebensmittelhandel, einen Fabriksverkauf vor Ort sowie einen eigenen Online-Shop. Das Unternehmen beschäftigt 120 Mitarbeiter. Es gibt keine eigene IT-Abteilung. Die IT wird von zwei internen Mitarbeitern sowie einem externen IT-Dienstleister betreut.

2. Netzwerk und Systeme

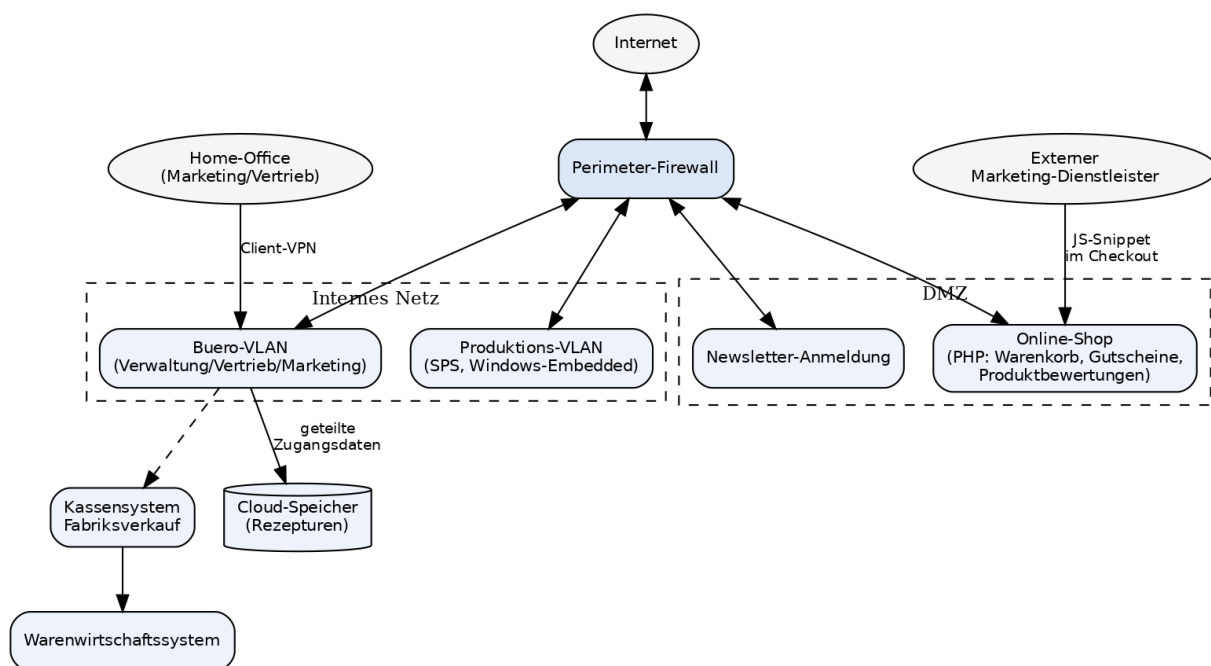


Abbildung 1: Netzwerktopologie Alpenzuckerl Manufaktur

- **Produktions-VLAN:** Steuerungen der Fertigungslinien (SPS auf älteren Windows-Embedded-Systemen), bisher ohne strikte Trennung vom Büronetz.



- **Büro-VLAN:** Verwaltung, Vertrieb, Marketing.
- **DMZ:** Online-Shop (eigenentwickelte PHP-Anwendung mit Warenkorb, Gutscheincodes, Produktbewertungen), Newsletter-Anmeldung.
- **Fabriksverkauf:** Kassensystem vor Ort, verbunden mit dem zentralen Warenwirtschaftssystem.
- **Home-Office:** Marketing- und Vertriebsmitarbeiter greifen über Client-VPN auf das interne Netz zu.
- **Cloud-Speicher:** Rezepturen und Produktionsverfahren (Betriebsgeheimnisse) liegen auf einem externen Cloud-Speicher, Zugriff über geteilte Zugangsdaten mehrerer Mitarbeiter.
- **Marketing-Dienstleister:** Ein externer Anbieter für Newsletter- und Empfehlungsmarketing ist per JavaScript-Snippet direkt in die Checkout-Seite des Online-Shops eingebunden.

Für die Anmeldung an den Büro-Arbeitsplätzen existiert kein zentrales Verzeichnisdienst-System, jeder Rechner verwaltet eigene lokale Benutzerkonten. Eine Ausnahme bildet der Zugriff auf den Cloud-Speicher für Rezepturen, der über geteilte Zugangsdaten mehrerer Mitarbeiter erfolgt (siehe oben).

3. Bereits aktive Sicherheitsmaßnahmen

- Perimeter-Firewall an der Internetanbindung.
- Antiviren-Software auf allen Büro-Arbeitsplätzen, zentral verwaltet durch den externen IT-Dienstleister.
- Zahlungsdaten werden nicht direkt gespeichert, sondern ausschließlich über den externen, zertifizierten Zahlungsdienstleister verarbeitet.
- Tägliches Backup des Warenwirtschaftssystems auf ein NAS am Standort Hallein.
- Verschlüsselte VPN-Verbindung für den Home-Office-Zugriff von Marketing und Vertrieb.
- Monatlicher automatisierter Schwachstellenscan des öffentlich erreichbaren Online-Shops durch den externen IT-Dienstleister.

4. Serverberechtigungen (Online-Shop-Server)

```
drwxr-xr-x  2 root      root          4096 Mär 01 08:00 config
-rw-r--r--  1 root      root          1900 Mär 01 08:00 config/database.yml
-rwxrwxrwx  1 deploy    www-data    13200 Mär 03 09:40 scripts/export_orders.sh
-rw-rw-rw-  1 www-data  www-data    4096  Mär 04 12:15 uploads/gutschein_import.csv
drwxrwxr-x  3 deploy    developers  4096  Mär 05 10:00 releases
-rw-r----- 1 root      shadowgrp  980   Feb 18 09:00 secrets.env
```

Prozessbenutzer des Webservers: www-data. Die Gruppe developers umfasst die beiden internen Entwickler des Shops.

5. Online-Shop: Anwendung und personenbezogene Daten

Architektur:

- **Frontend:** serverseitig gerenderte PHP-Seiten für Katalog, Warenkorb und Checkout.
- **Backend:** PHP-Anwendung mit direktem Zugriff auf eine MySQL-Datenbank.



- **Authentifizierung:** Kundenlogin per E-Mail-Adresse und Passwort, serverseitige Session nach erfolgreichem Login.
- **Schnittstellen:** eingebundenes Marketing-Snippet eines externen Dienstleisters (siehe Abschnitt 2), Anbindung an den externen Zahlungsdienstleister.

Der Online-Shop verwaltet Kundenkonten (Name, Adresse, E-Mail), gespeicherte Zahlungsdaten über einen externen Zahlungsdienstleister, Bestellhistorien, freiwillige Angaben zu Unverträglichkeiten und Allergien für personalisierte Produktempfehlungen (besondere Kategorie personenbezogener Daten) sowie Newsletter-Präferenzen. Zusätzlich erfasst das Zutrittssystem der Produktionshalle Zeiterfassungsdaten der Mitarbeiter.

Im Rahmen eines internen Code-Reviews liegen zwei vollständige, lauffähige und inspizierbare Dateien des Shops als Begleitmaterial bei (Ordner `Begleitmaterial_Gruppe1/`):

- `gutschein_check.php`, Gutschein-Prüfung im Warenkorb
- `bewertung.php`, Produktbewertungsfunktion

Diese Dateien enthalten bewusst eingebaute Schwachstellen für das Code-Review in Aufgabenblatt 2.

6. Sicherheitsvorfall: Auszug aus dem Incident-Report

Klassifizierung: Web-Skimming über kompromittierten Drittanbieter (Magecart-artiger Angriff), mit vorausgehendem Supply-Chain-Einbruch beim Marketing-Dienstleister **Betroffene Systeme:** Checkout-Seite des Online-Shops, eingebundenes Marketing-Snippet `adwise-tracker.js`, Konten des Marketing-Dienstleisters **Rekonstruiert anhand von:** forensischem Bericht des Marketing-Dienstleisters “AdWise Analytics”, CDN-Auslieferungslog, CSP-Verletzungsberichten (Content-Security-Policy Reports) des Browsers, manueller Quelltextprüfung, Betrugsmeldungen des Zahlungsdienstleisters, Registrar- und DNS-Abfragen zu den verwendeten Domains

- **Woche 1, Dienstag** [Quelle: forensischer Bericht von AdWise Analytics, im Nachhinein angefordert]: Ein Mitarbeiter im Kundensupport von AdWise Analytics öffnet eine E-Mail mit einem Link zu einem gefälschten Login-Portal des internen Content-Management-Systems und gibt dort seine Zugangsdaten ein. Multi-Faktor-Authentifizierung war für dieses Konto laut Bericht nicht aktiviert.
- **Woche 1, Mittwoch** [Quelle: Admin-Audit-Log von AdWise Analytics]: Mit den erbeuteten Zugangsdaten meldet sich ein bislang unbekannter Akteur im CMS an, über das Kunden-Snippets für das Auslieferungs-CDN verwaltet werden, und legt eine neue, geringfügig abweichende Version der Datei `adwise-tracker.js` als „geplante Aktualisierung“ mit verzögertem Rollout an.
- **Woche 2, Montag** [Quelle: CDN-Auslieferungslog von AdWise Analytics]: Ab diesem Datum liefert das CDN für alle Kunden, die das Snippet einbinden, darunter auch Alpenzuckerl, die manipulierte Version aus. Ein Quelltext-Diff gegenüber der vorherigen Version zeigt zusätzlichen, mit `atob()` obfuskirten Code, der bei Ausführung einen `fetch()`-Aufruf an die Domain `cdn-assets-secure.net` registriert.
- **Woche 2, Dienstag** [Quelle: DNS- und Registrar-Abfrage, nachträglich durchgeführt]: Die Domain `cdn-assets-secure.net` wurde laut WHOIS-Eintrag neun Tage zuvor registriert und ist auf denselben Hosting-Anbieter eingetragen wie zwei weitere, in anderen Vorfallsberichten bereits bekannte Skimming-Domains.
- **Woche 2, Mittwoch bis Woche 4, Donnerstag** [Quelle: nachträgliche Analyse des archivierten



Seitenquelltexts]: Der nachgeladene Code registriert einen Event-Listener auf den Eingabefeldern `#cc-number`, `#cc-expiry` und `#cc-cvv` des Checkout-Formulars und überträgt deren Inhalt bei jeder Eingabe per `fetch()` an `https://cdn-assets-secure.net/collect`. Der Code prüft zusätzlich per `navigator.userAgent`, ob es sich um einen automatisierten Testbrowser handelt, und unterdrückt in diesem Fall die Übertragung, um Sicherheitsscanner zu täuschen.

- **Woche 2, Freitag** [Quelle: CSP-Verletzungsbericht (Content-Security-Policy Report) im Browser eines technisch versierten Kunden, per E-Mail an den Support gemeldet]: Ein einzelner Kunde meldet eine Browser-Warnmeldung beim Checkout, die auf eine blockierte Verbindung zu einer unbekannten Domain hinweist. Die Meldung wird vom Support als Einzelfall ohne Weiterverfolgung abgelegt.
- **Woche 3, Montag bis Mittwoch** [Quelle: Betrugsmeldungen des Zahlungsdienstleisters]: Zunächst vereinzelte, kleine Testtransaktionen (unter 5 EUR) mit den abgegriffenen Kartendaten werden bei mehreren unabhängigen Onlinehändlern registriert, ein typisches Muster zur Prüfung der Gültigkeit gestohlener Kartendaten (Card Testing) vor dem eigentlichen Missbrauch.
- **Woche 4, Mittwoch** [Quelle: Betrugsmeldungen des Zahlungsdienstleisters]: Der Zahlungsdienstleister meldet eine deutliche Zunahme auf rund 60 gemeldete Betrugsfälle mit größeren Beträgen bei Karten, die zuletzt im Alpenzuckerl-Shop verwendet wurden.
- **Woche 4, Donnerstag** [Quelle: interne Prüfung der Support-Historie]: Bei der Nachschau wird die in Woche 2 abgelegte CSP-Meldung eines Kunden wiedergefunden und dem laufenden Vorfall zugeordnet.
- **Woche 4, Freitag** [Quelle: manuelle Quelltextprüfung durch den internen IT-Dienstleister]: Ein Vergleich des aktuellen Seitenquelltexts mit einer archivierten Vorversion bestätigt die zusätzliche, obfuskierte Skript-Referenz.
- **Woche 5, Montag** [Quelle: Abstimmung mit AdWise Analytics]: AdWise Analytics bestätigt den eigenen CMS-Einbruch aus Woche 1 als Ursache und entfernt die manipulierte Snippet-Version für alle Kunden.
- **Woche 5, Mittwoch** [Quelle: Abstimmung mit dem Zahlungsdienstleister]: Der Kompromittierungszeitraum wird auf Woche 2 Montag bis Woche 4 Freitag eingegrenzt. Alle in diesem Zeitraum über den Shop getätigten Zahlungen werden als potenziell betroffen eingestuft und dem Zahlungsdienstleister zur Kartensperrung gemeldet.

7. Begleitmaterial

- Begleitmaterial_Gruppe1/gutschein_check.php, bewertung.php, Codedateien des Online-Shops
- Begleitmaterial_Gruppe1/docker-compose.yml, Setup, um die beiden Beispiele lokal auszuprobieren